achieved with timestamps, nonces, or challenge-response protocols. Preventing replay requires storing per-device state, such as a monotonically increasing counter or recently used nonces.

- REST APIs can prevent replay by making use of authenticated request objects that contain an ETag that identifies a specific version of the resource being acted on. The ETag should change whenever the resource changes to prevent replay of previous requests.
- The OAuth2 device grant can be used by devices with no input capability to obtain access tokens authorized by a user. The ACE-OAuth working group at the IETF is developing specifications that adapt OAuth2 for use in constrained environments.
- Devices may not always be able to connect to central cloud services. Offline authentication and access control allow devices to continue to operate securely when disconnected. Self-contained token formats can include credentials and policies to ensure authority isn't exceeded, and proof-of-possession (PoP) constraints can be used to provide stronger security guarantees.

[1] One of the few drawbacks of the NaCl CryptoBox and SecretBox APIs are that they don't allow authenticated associated data.

[2] If the server can determine that the current state of the resource happens to match the requested state anyway then it can also return a success status code as if the request succeeded in this case. But in this case the request is really idempotent anyway.

[3] Strangely, the device authorization grant is not yet supported.